

Hoe wij jouw gegevens beschermen

Een overzicht van de technische maatregelen die ArnoBot heeft getroffen om jouw privacy en de veiligheid van jouw data te waarborgen.

Versie 1.0 · 26 juni 2026 · privacy@arno.bot

Vertrouwen is de basis van alles wat ArnoBot doet. Jij deelt persoonlijke inzichten, zakelijke uitdagingen en coachingsgesprekken met ons platform. Het is onze verantwoordelijkheid om die informatie te behandelen met de grootst mogelijke zorg. Dit document legt uit hoe wij dat technisch hebben ingericht.

WAAR JOUW GEGEVENS STAAN

Infrastructuur en hosting

ArnoBot maakt gebruik van gevestigde, gecertificeerde partijen voor alle infrastructurele onderdelen. Wij beheren zelf geen servers.

Onderdeel	Partij en garantie
Hosting	Vercel — serverless, wereldwijd CDN, HTTPS verplicht op alle verbindingen
Database	Supabase — PostgreSQL in de EU, versleuteld in rust (AES-256) en tijdens transport (TLS 1.2+)
Authenticatie	Clerk — SOC 2 Type II gecertificeerd, LinkedIn OAuth
AI-verwerking	Anthropic — jouw berichten worden verwerkt om een antwoord te genereren en daarna niet permanent opgeslagen
E-mail	Resend — transactionele e-mail via DKIM-geverifieerd domein

WIE ER BIJ KAN

Authenticatie en toegangsbeheer

Toegang tot jouw data is strikt beperkt tot jou. Wij hebben het volgende ingericht:

- **Inloggen via LinkedIn OAuth** Wij slaan nooit een wachtwoord op. Authenticatie verloopt via Clerk, dat jouw sessie beheert met kortlevende JWT-tokens.
- **Sessiecontrole op elke route** Elke API-aanroep verifieert eerst de actieve sessie. Routes die geen geldig token terugkrijgen, geven een 401-fout en stoppen direct.
- **Databasetoegang per gebruiker** De databasesleutel met volledige schrijfrechten (service role key) is uitsluitend beschikbaar op de server en nooit zichtbaar in de browser.
- **Strikt gescheiden admintoegang** Beheerdersfuncties zijn beveiligd met een aparte sleutel die niet via de normale inlogflow bereikbaar is.

Gegevensisolatie

Een veelvoorkomende kwetsbaarheid in webapplicaties is dat een gebruiker toegang kan krijgen tot andermans data door een parameter in de URL aan te passen — dit heet IDOR (Insecure Direct Object Reference). ArnoBot beschermt hier actief tegen.

Elke API-route haalt jouw identiteit op uit de geverifieerde sessie. Een userId in een URL of requestbody wordt nooit vertrouwd — alleen de sessie bepaalt welke data wordt teruggegeven.

- **Exportfunctie** Het downloaden van jouw gegevens werkt op basis van jouw ingelogde sessie, nooit op basis van een ID in de URL.
- **Teamdata** Een manager ziet uitsluitend data van leden die aantoonbaar tot hetzelfde team behoren.

AANVALLEN VOORKOMEN

Wat er op ons afkomt en hoe wij het stoppen

Onderstaand overzicht laat zien welke aanvalstypen wij tegenkomen en welke maatregel precies wat afdekt.

Aanval	Hoe ArnoBot dit afdekt
Volumetrische aanvallen (DDoS)	Vercel Edge Network absorbeert grote hoeveelheden verkeer automatisch op netwerkniveau
API-misbruik (hammering)	Maximaal 5 chatverzoeken per IP per minuut; admin-login geblokkeerd na 10 mislukte pogingen per 15 minuten
Prompt injection	14 detectiepatronen (Nederlands en Engels) onderscheppen pogingen om het AI-model te manipuleren of gevoelige data te ontfutselen
Bots en vulnerability scanners	Middleware blokkeert automatisch bekende scannerpaden zoals .env, .git, wp-admin en phpMyAdmin
SQL-injectie	Supabase gebruikt geparametriseerde queries; bovendien begrenst Row Level Security wat elke gebruiker mag opvragen
Cross-site scripting (XSS)	Content-Security-Policy headers beperken welke scripts de browser mag uitvoeren
Credential stuffing	Inloggen zonder wachtwoord via LinkedIn OAuth. Er valt niets te raden of te stelen.
Informatielekken via foutmeldingen	Technische foutdetails (databasefouten, stack traces) worden nooit aan de gebruiker getoond, alleen server-side gelogd

Wat er met jouw tekst gebeurt

- **Lengtelimieten** Alle tekstvelden hebben een maximum: chatberichten max 4.000 tekens, oefengesprekken max 2.000 tekens, vrije invoervelden max 500 tekens. Dit voorkomt misbruik van rekenkracht.
- **Sanitatie** Tekst die wordt doorgestuurd naar externe diensten wordt eerst ontdaan van tekens die tot injectie kunnen leiden.
- **E-mailvalidatie** E-mailadressen worden gecontroleerd op geldigheid voordat ze worden verwerkt of opgeslagen.

HTTP-beveiligingsheaders

Elke pagina van ArnoBot wordt geserveerd met een set beveiligingsheaders die de browser instrueert hoe hij de inhoud moet behandelen. Dit beschermt jou ook als er iets misgaat aan de browserkant.

- **X-Frame-Options: DENY** Voorkomt dat de ArnoBot-interface in een verborgen iframe op een andere site kan worden geladen (clickjacking).
 - **X-Content-Type-Options: nosniff** Voorkomt dat de browser bestanden als een ander type interpreteert dan bedoeld.
 - **Strict-Transport-Security (HSTS)** Dwingt de browser om altijd HTTPS te gebruiken, ook als je per ongeluk http:// typt.
 - **Content-Security-Policy** Beperkt welke externe bronnen (scripts, lettertypen, afbeeldingen) de browser mag laden.
 - **Referrer-Policy** Beperkt welke URL-informatie wordt meegestuurd bij externe links.
 - **Permissions-Policy** Schakelt browserfeatures uit die ArnoBot niet gebruikt: camera, microfoon en locatie-toegang.
 - **X-Powered-By: verborgen** De technologie achter ArnoBot wordt niet aan derden bekendgemaakt.
-

Afhankelijkheden en updates

Moderne webapplicaties zijn opgebouwd uit honderden externe softwarepakketten. Kwetsbaarheden in die pakketten kunnen ook jouw data raken. ArnoBot houdt dit actief bij.

- **Regelmatige audit** Alle npm-pakketten worden gecontroleerd op bekende kwetsbaarheden. Kwetsbaarheden in runtime-code worden direct verholpen.
 - **Nul bekende runtime-kwetsbaarheden** Na de laatste securitysessie zijn alle kwetsbaarheden in code die daadwerkelijk in productie draait verholpen. Resterende meldingen betreffen uitsluitend interne bouwtooling die nooit in aanraking komt met gebruikersdata.
 - **Tijdslimiet op AI-aanroepen** Alle verbindingen met het AI-model hebben een maximale looptijd. Dit voorkomt dat een hanerige of kwaadwillende aanroep ongecontroleerd resources verbruikt.
-

Inzage, export en verwijdering

Op grond van de Algemene Verordening Gegevensbescherming (AVG) heb je de volgende rechten, die je direct vanuit jouw account kunt uitoefenen:

- **Recht op inzage (art. 15 AVG)** Download al jouw opgeslagen gegevens via Accountinstellingen ' Jouw data.

- **Recht op verwijdering (art. 17 AVG)** Verzoek tot verwijdering van jouw account en alle bijbehorende data via Accountinstellingen ' Account verwijderen. Verzoeken worden handmatig verwerkt binnen de wettelijke termijn.
- **Recht op rectificatie (art. 16 AVG)** Pas je profiel en persoonlijke gegevens aan via de profielpagina.
- **Datalekken** In geval van een datalek word je binnen 72 uur geïnformeerd via het e-mailadres dat aan jouw account is gekoppeld.

CONTACT

Vragen over jouw data

Heb je vragen over hoe ArnoBot met jouw gegevens omgaat, of wil je een van jouw AVG-rechten uitoefenen?

Stuur een e-mail naar:

privacy@arno.bot

Verzoeken worden binnen 10 werkdagen beantwoord.